Phishing Email Detection & Awareness Report

Analysis of six emails and guidance for employees

Programme: Future Interns, Cyber Security Task 2 (2026)

Prepared by: Sudip Bhalla

Date: 10 October 2026

Intended readers: Non-technical staff of a mid-sized company, and the IT team that supports them

All links and addresses in the evidence files are written in defanged form (for example hxxp://example[.]com). No link in any sample was opened during this work.

1. Purpose and summary

Most successful phishing attacks do not beat a company's systems. They beat a person who was busy, worried or curious for ten seconds. This report looks at six emails the way a security analyst would, shows what gave each one away, and turns the findings into advice that ordinary employees can use.

Result at a glance

I reviewed six emails: one template from the task brief, four real unsolicited emails from a public phishing collection, and one genuine Google security alert from my own inbox. Four were classified as Phishing, one as Suspicious and one as Safe.

#	Email	SPF / DKIM / DMARC	Score	Classification
01	Account-lock template	No headers	6	Phishing (content only)
02	Fake Visa prize	none / none / none	8	Phishing
03	Fake energy tariff refund	fail / fail / none	9	Phishing
04	Fake reward	none / fail / none	8	Phishing
05	Roof repair advert	pass / pass / pass	5	Suspicious
06	Google security alert	pass / pass / pass	0	Safe

What this work showed

- **Names are easy to fake.** Three of the four phishing emails put a trusted-sounding name ("Visa", "Klantenservice Energie", "Emily @ Rewards") on an address that had nothing to do with it.
- **The links gave the strongest evidence.** The two link domains I could check were registered 9 and 41 days before the emails were sent, and 11 and 14 of 93 security vendors flag them as phishing or malicious.
- **Passing the technical checks is not enough.** The roof advert passed SPF, DKIM and DMARC and was still misleading, because it used three unrelated domains.
- **A genuine email behaves differently.** The Google alert passed every check and every link stayed on Google's own domains.

2. Method and tools

Each email went through the same five checks, in the same order, so the results can be compared.

1. **Headers.** Are SPF, DKIM and DMARC present and passing? Do the sender and the delivery path make sense?
2. **Sender.** Does the display name match the real address and its domain?

3. **Links.** Where does each button really go, how old is that domain, and do security vendors flag it?
4. **Language.** Is there urgency, a threat, a reward that is too good, or a generic greeting?
5. **Request.** What does the email want me to do: click, log in, pay, share a code?

Tools used

Tool	What I used it for
Google Admin Toolbox: Messageheader	Reading SPF, DKIM and DMARC results and the sender details from raw headers
MXToolbox: Email Headers	A second opinion on alignment and the relay path
ICANN Lookup (RDAP)	Domain creation dates and nameservers
VirusTotal	Checking link domains against security vendors (searched only, never visited)
Plain text editor	Reading the raw .eml files safely, without opening them in a mail program

Scoring rule

To keep the classification consistent, each email earns points for red flags.

Red flag	Points	
SPF, DKIM or DMARC fails or is missing	2	
Display name does not match the sender address or domain	2	
Link domain is new (under 3 months), flagged by VirusTotal, or hidden behind a tracker or shared hosting page	2	
Urgency, a threat, or a reward that is too good to be true	1	
Generic greeting or no personalisation	1	
Asks for credentials, money or a click to “claim” something	1	
Sender cannot be identified at all (no company, no real address)	1	

Safe	0 to 1 points and every authentication check passes
Suspicious	2 to 5 points, or the checks pass but the sender or content is deceptive
Phishing	6 points or more, with a failed or missing authentication check or a deceptive, flagged link

Handling the samples safely

- No link was opened and no attachment was opened. The emails were read as plain text.

- Domains were checked only through lookup sites (ICANN, VirusTotal).
- In the evidence files, links and addresses are defanged, and hidden padding text and tracking blobs were removed.
- My own email address was removed from the genuine sample before it was saved.

3. Analysis of each email

Email 01: “Urgent: Your Account Will Be Locked”

This is the example email from the task brief. It has no headers, so only its content could be assessed. It is included because it shows the classic pattern in its simplest form.

Source	Task brief (template example)
Sender	“Security Team”: no company name, no address
Link	hxxp://secure-account-verify[.]com, a generic name that does not belong to any recognisable company
Language	“Dear User”, “suspicious activity”, “verify your details immediately”, “within 24 hours”, “permanent account lock”
What it wants	You to click “Verify Now” and enter your account details

Score 6: Phishing (content only). Urgency 1, generic greeting 1, request to verify details 1, generic look-alike link 2, unidentifiable sender 1. Headers and domain age were not available.

Email 02: Fake Visa World Cup prize

A Portuguese-language email dressed as a Visa promotion, offering cash prizes and a R$ 100,000 final draw to anyone who spends more than R$ 10 with a Visa card. Sent on 6 July 2026.

Authentication	SPF none, DKIM none, DMARC none (both analysers)
Sender	Display name “Visa” on nao-responder-Visa316004777@promocoes316004777. That domain has no valid ending, so it is not a real internet domain. The reply address (suporte@notificacoes) has the same problem.
Delivery	The sending server announced itself as 127.0.0.1 (the machine itself), using “Custom Mailer v1.0” from IP 95.179.194.86. Microsoft gave it a spam score of 7 and put it in Junk.
Link	The “Quero Participar” button goes to a page on Google Cloud Run (run[.]app). The web address contains the recipient’s own email address so clicks can be tracked. run.app itself was registered in 2018 and belongs to Google’s hosting service. Anyone can publish a page there, so the platform’s reputation says nothing about this page.
Language	A very large prize for a tiny purchase, a draw calendar, and a footer claiming it was “sent securely to Visa customers”, which adds fake trust.

Score 8: Phishing. Missing authentication 2, name does not match sender 2, tracked link on shared hosting 2, too-good reward 1, click to take part 1.

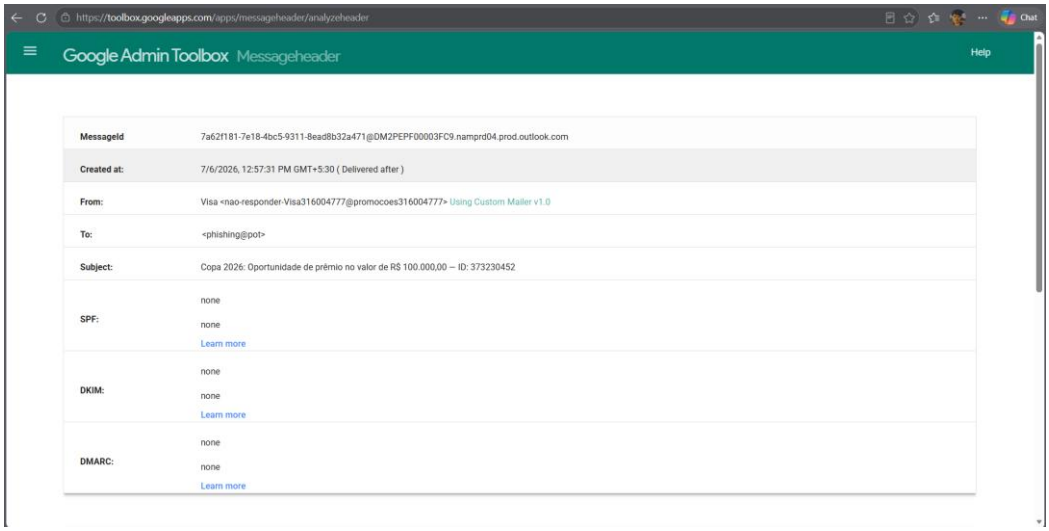


Figure 1. Google Messageheader result for Email 02: SPF, DKIM and DMARC all "none".

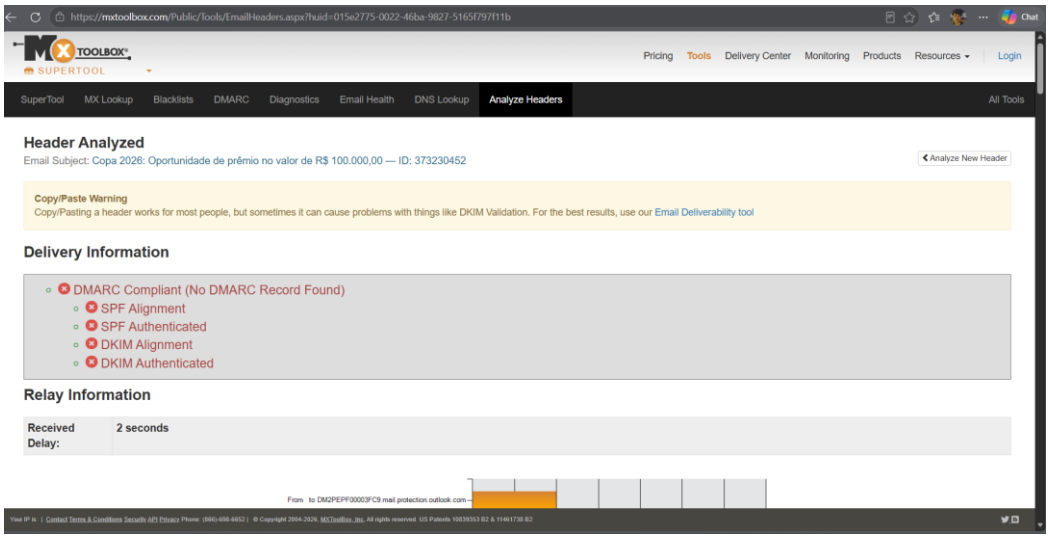


Figure 2. MXToolbox result for Email 02: every authentication and alignment check failed.

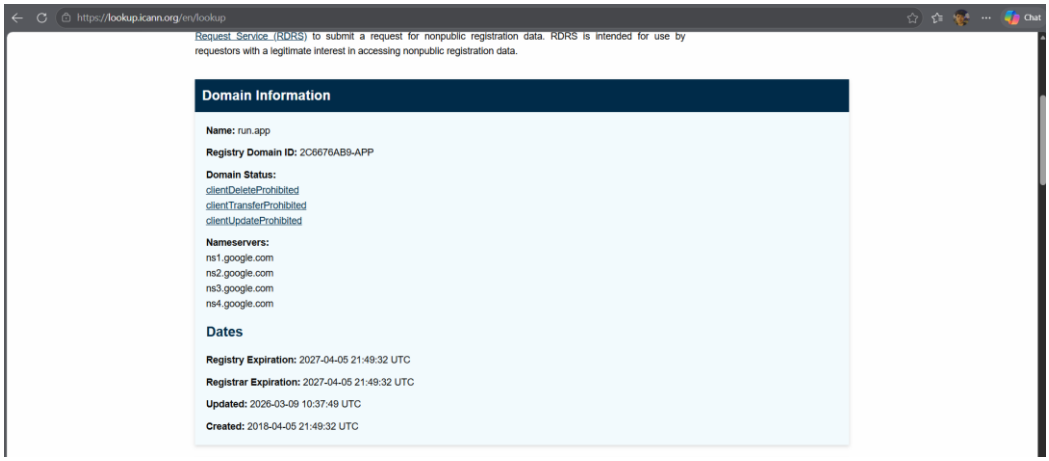


Figure 3. Registration record for run.app: a legitimate Google platform that anyone can host pages on.

Email 03: Fake energy tariff refund

A Dutch email, sent 31 July 2026, claiming the reader is overpaying €700 a year on their energy bill and can fix it in 30 seconds.

Authentication	SPF fail, DKIM fail, DMARC none. The Microsoft check (compauth) also failed. Spam score 9.
Sender	Display name “Klantenservice Energie” (energy customer service) on emery.carter@infowebtech77[.]onmicrosoft[.]com, a free Microsoft trial address, not an energy company. It was sent through a Google mail server (209.85.208.48).
DKIM	Signed by send.workwithshadow.com, which is not the sender’s own domain, and the signature did not verify.
Links	Every button goes to vigit99[.]com, never to an energy provider. Some links contain a unique /track/ code per recipient. The domain was registered on 22 July 2026, nine days before the email. 11 of 93 VirusTotal vendors flag it as phishing or malicious. It resolves to 89.252.175.139.
Language	“Dear recipient”, status “Urgent”, a “dossier” number, a claimed loss of €700, and a “claim your saving” button. No company name, no customer number.

Score 9: Phishing. Failed authentication 2, name does not match sender 2, new and flagged link domain 2, urgency 1, generic greeting 1, claim button 1.

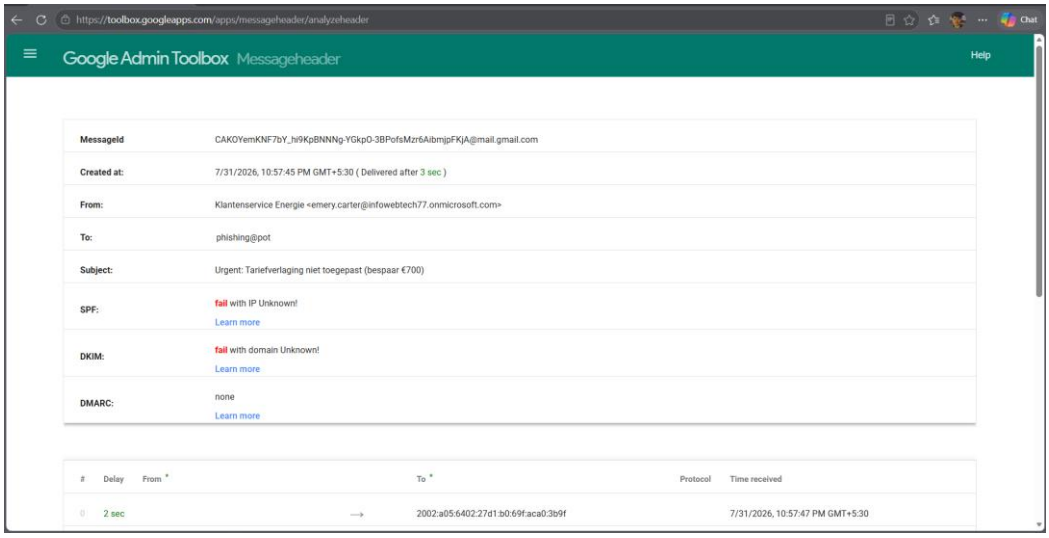


Figure 4. Google Messageheader result for Email 03: SPF and DKIM fail.

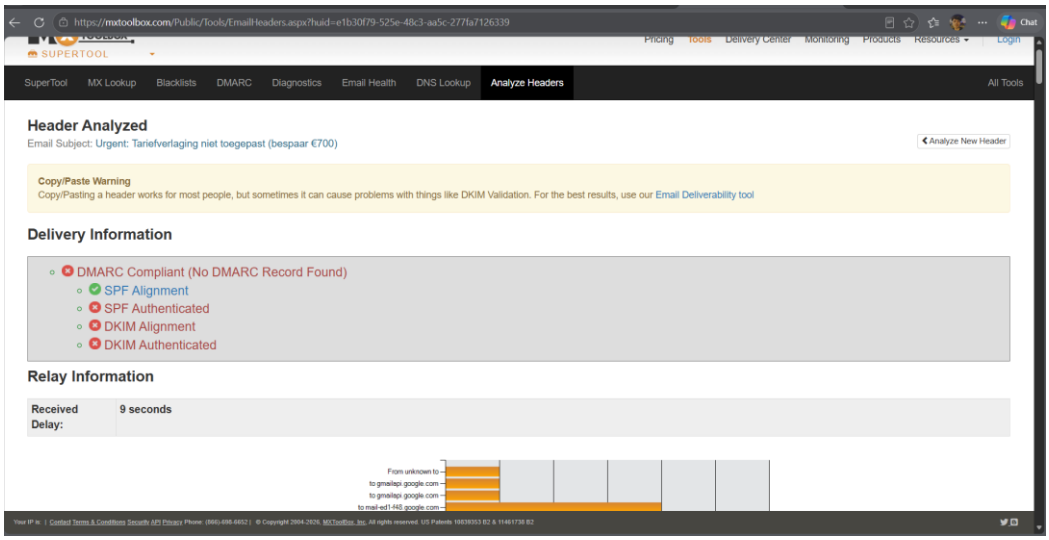


Figure 5. MXToolbox result for Email 03: SPF and DKIM authentication fail and there is no DMARC record.

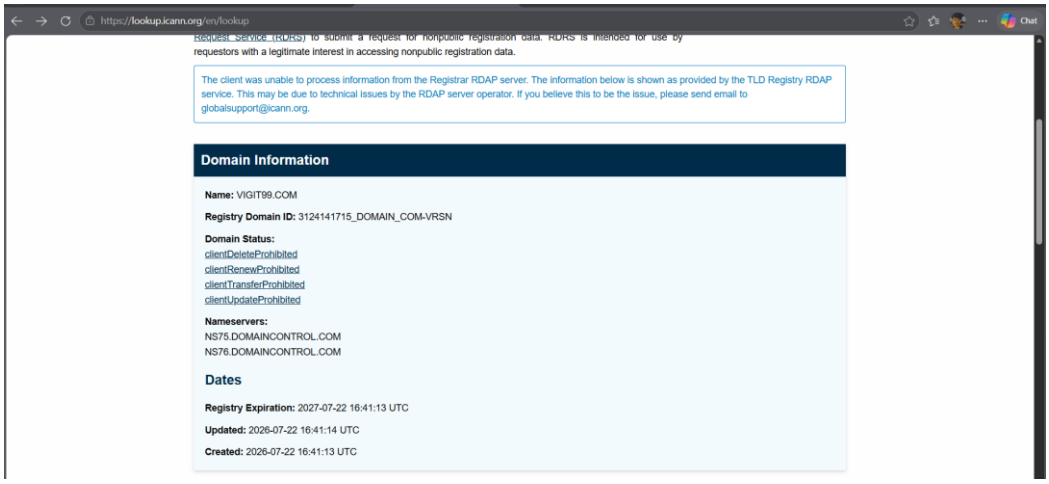


Figure 6. Registration record for vigit99.com: created 22 July 2026.

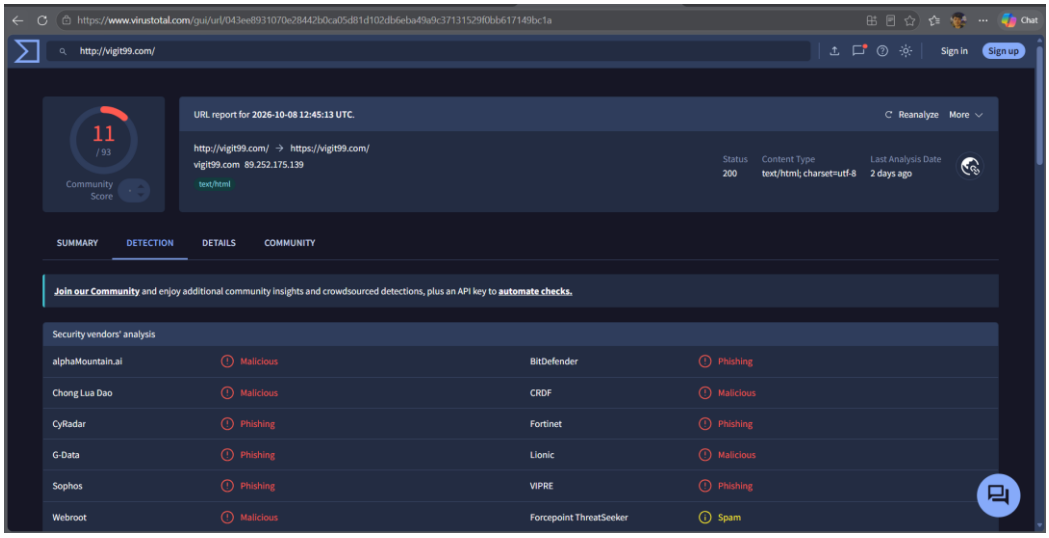


Figure 7. VirusTotal result for vigit99.com: 11 of 93 vendors flag it.

Email 04: Fake reward

An English email, sent 31 July 2026, with the subject “LAST CHANCE: Claim your confirmed reward now”. The only readable text in the body is “Your Deposit 5363019773 has been successfully received”, a fake deposit notice meant to make the reader click to find out what it is about.

Authentication	SPF none, DKIM fail, DMARC none. The Microsoft check (compauth) also failed. Spam score 8.
Sender	Display name “Emily @ Rewards” on max.lopez1@cloudmatrixtech444[.]onmicrosoft[.]com. The first name in the display name does not match the address, and the domain is another free Microsoft trial tenant.
DKIM	Signed by send.workwithshadow.com, the same signer as Email 03, and the signature again failed to verify.
Links	All links go to vigit88[.]com. It was registered on 20 June 2026, 41 days before the email. 14 of 93 VirusTotal vendors flag it as phishing. It resolves to 172.232.128.247.

Link to Email 03	workwithshadow.com was registered in October 2024 and sits behind Cloudflare, so it is not a brand-new domain. It looks like a bulk sending service used by both campaigns. The link domains behind it (vigit99 and vigit88) are both under three months old.

Score 8: Phishing. Failed authentication 2, name does not match sender 2, new and flagged link domain 2, pressure wording 1, click to claim 1.

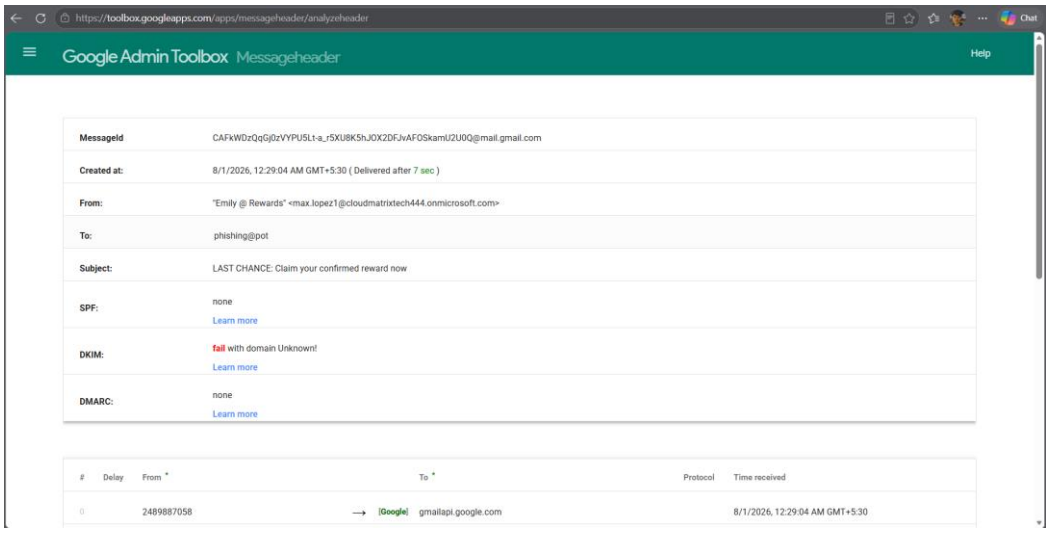


Figure 8. Google Messageheader result for Email 04.

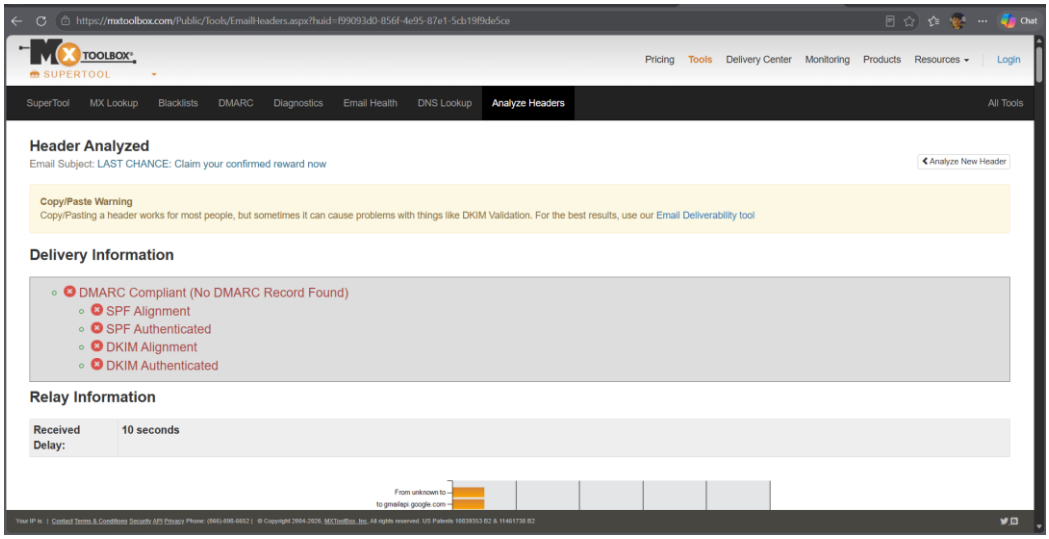


Figure 9. MXToolbox result for Email 04.

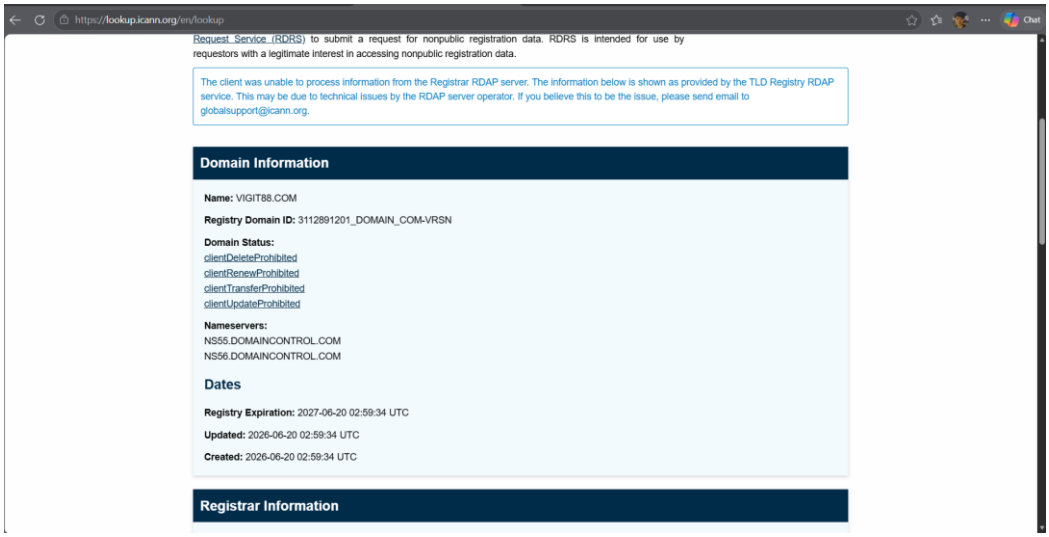


Figure 10. Registration record for vigit88.com: created 20 June 2026.

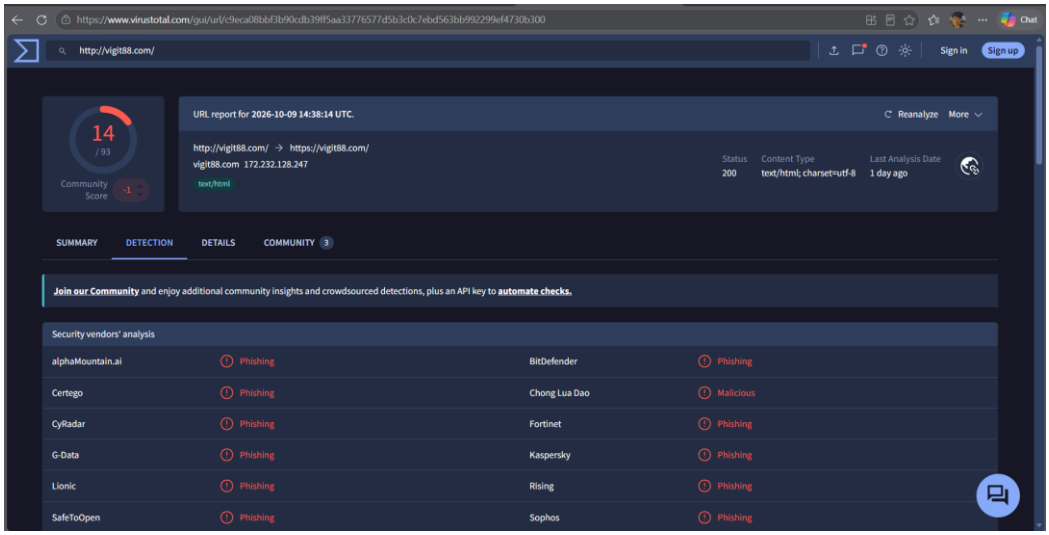


Figure 11. VirusTotal result for vigit88.com: 14 of 93 vendors flag it.

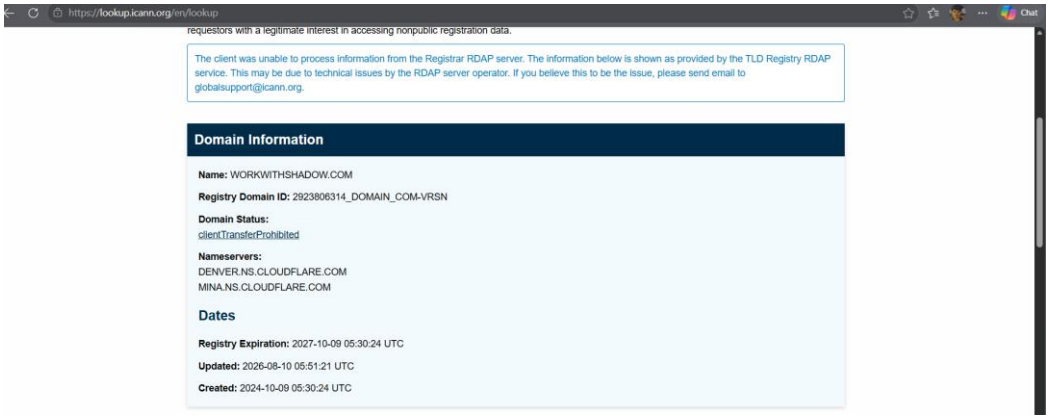


Figure 12. Registration record for workwithshadow.com, the DKIM signer in Emails 03 and 04.

Email 05: Roof repair advert

An email sent 2 July 2026 asking “Is Your Roof Still Safe?”. It is advertising rather than an obvious scam, but it hides who is really behind it.

Authentication	SPF pass, DKIM pass, DMARC pass. DMARC passed through SPF only: the DKIM signature belongs to a different domain than the one in the From line.
Sender	Three unrelated domains in one message: From “HomeBuddy Partner” on jwgmedia[.]com, DKIM signed for mysteryphotographer[.]com, replies go to brendamurphyrealestate[.]com.
Links	The pictures link to a page on Google Cloud Storage (storage.googleapis.com), which anyone can host, so the link tells the reader nothing about who is behind it. A hidden 1-pixel image loads from a fourth domain to track who opens the email.
Delivery	Microsoft gave it a spam score of 5 and moved it to Junk.
Language	A short fear-based hook about roof damage, with an “unsubscribe” that works by replying to an address on yet another domain.

Score 5: Suspicious. Sender and signing domains do not match 2, link hidden behind shared hosting 2, fear-based hook 1. It is not clearly malicious, but nobody can tell who is really sending it.

Why the two analysers disagree. Google Messageheader reads the verdict that Microsoft recorded when the email arrived in July: SPF, DKIM and DMARC all passed. MXToolbox checks the sender’s DNS records as they are today and finds no DMARC record and failures for SPF and DKIM. The most likely reason is that the sending domains’ records have changed or been removed since. This is a useful point in itself: throwaway sending domains often disappear soon after a campaign. The original delivery-time result is the one used for scoring. The email also took four days to arrive (sent 2 July, received 6 July), which is unusual for normal mail.

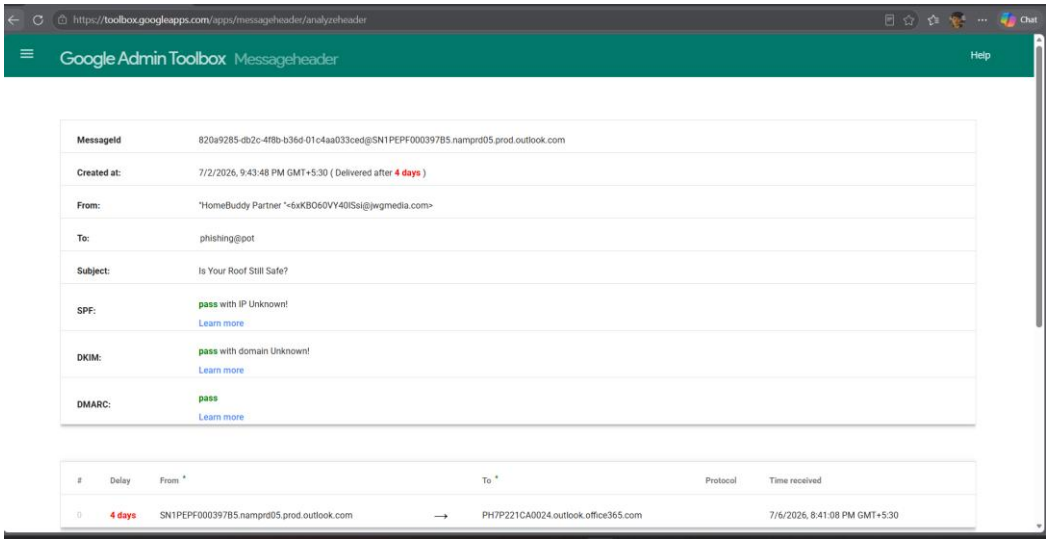


Figure 13. Google Messageheader result for Email 05: SPF, DKIM and DMARC all pass, delivered 4 days after it was sent.

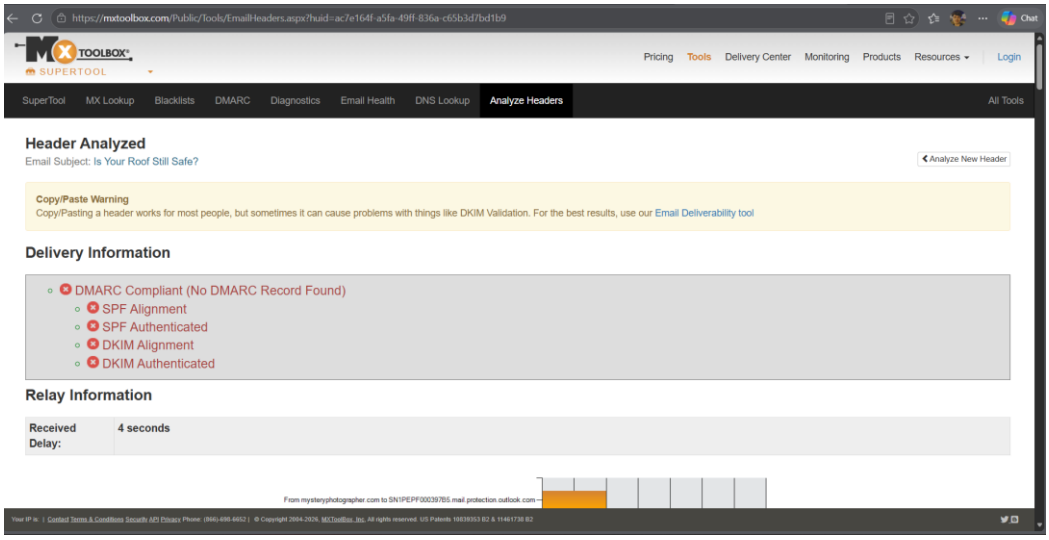


Figure 14. MXToolbox re-check of Email 05 (run later): it finds no DMARC record and fails SPF and DKIM. See the note above.

Email 06: Google security alert (genuine)

A “Security alert” from Google telling me my account password was changed, received in my own inbox on 13 September 2026. I added it as the safe comparison.

Authentication	SPF pass, DKIM pass (signed by accounts.google.com), DMARC pass with the strictest policy, p=REJECT.
Sender	Google <no-reply@accounts.google.com>, a real Google domain. Sent from a Google server (209.85.220.73).
Links	Only accounts.google.com and myaccount.google.com. Nothing leaves Google’s own domains.
Language	Calm and factual. It names my actual account, has no deadline and no threat, and does not ask me to type anything into the email.

Score 0: Safe. The classification rests on authentication, domain and links all agreeing, not on the email merely looking like Google.

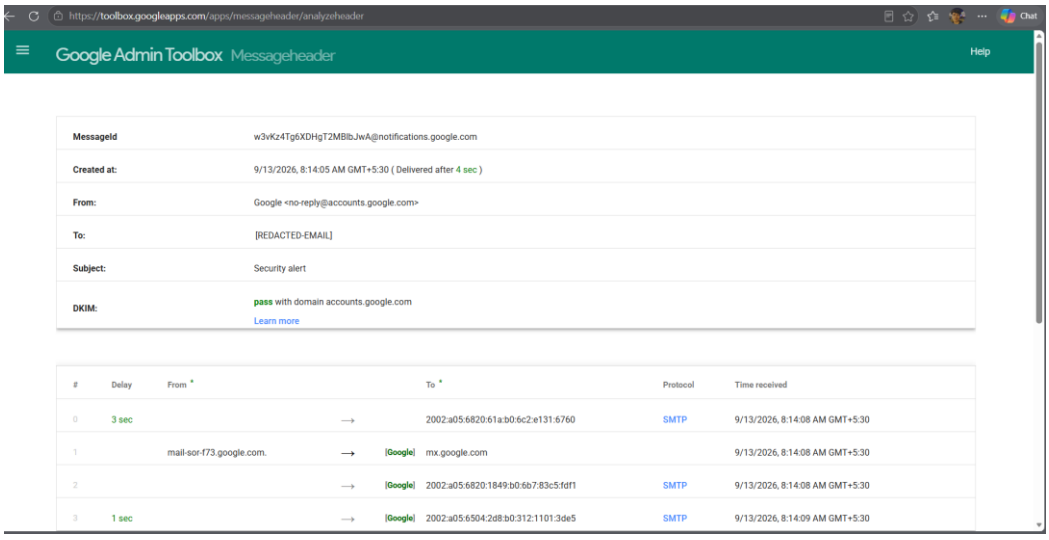


Figure 15. Google Messageheader result for Email 06: DKIM passes for accounts.google.com (my address is redacted).

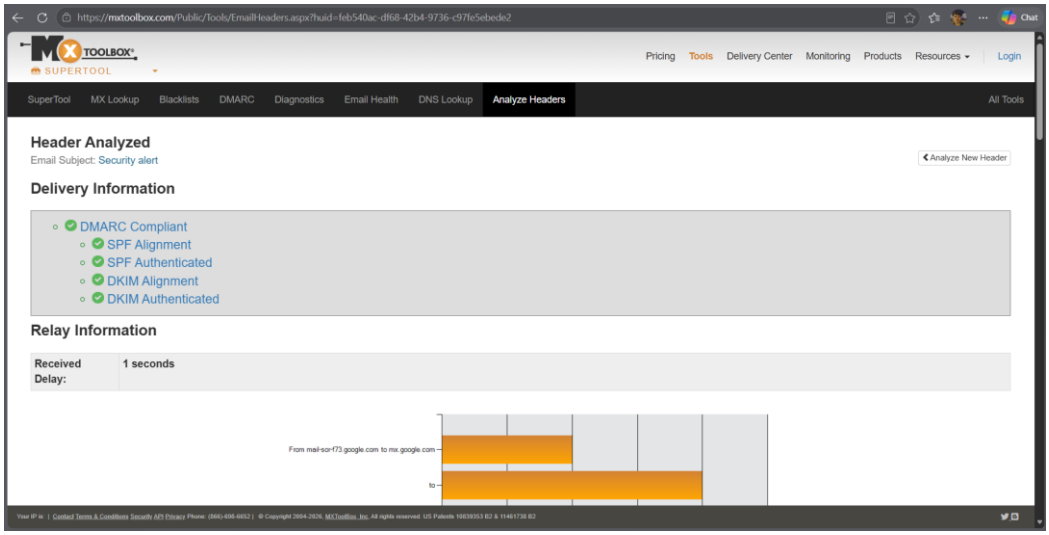


Figure 16. MXToolbox result for Email 06: DMARC, SPF and DKIM all pass and align.

4. Summary of results

#	Email	SPF / DKIM / DMARC	Main reason	Class
01	Account-lock template	No headers	Urgency, generic greeting, request to verify, generic look-alike link	Phishing
02	Fake Visa prize	none / none / none	Unauthenticated, brand name on a non-domain address, tracked link on shared hosting	Phishing
03	Fake energy tariff	fail / fail / none	Fails authentication, impersonates a utility, links to a 9-day-old flagged domain	Phishing
04	Fake reward	none / fail / none	Reward bait, 41-day-old flagged domain, same sending service as Email 03	Phishing
05	Roof advert	pass / pass / pass	Three unrelated domains, hidden tracking, hides the real sender	Suspicious
06	Google alert	pass / pass / pass	All checks pass, links stay on Google's own domains	Safe

Common patterns across the four phishing emails: a trusted name with a mismatched address, pressure or a reward, a button that goes to a domain nobody has heard of, and no real personalisation.

5. How these attacks work

The attacker only needs one person to follow these steps. Email 03 shows each one.

1. **Bait.** A message arrives that looks official and creates a feeling: worry, greed or curiosity. In Email 03 it is "you are paying €700 too much".
2. **Click.** The reader presses the button. The address behind it is a new domain with a long unique code, so the attacker knows exactly who clicked.
3. **Fake page.** The page asks for something: a login, bank details, a card number or a code sent to the phone.
4. **Theft.** Whatever is typed goes straight to the attacker, who can use it within minutes.
5. **Reuse.** If the same password is used elsewhere, the attacker tries it on email, banking and work accounts.

Most of the attack happens in the first two steps, before anything technical goes wrong. That is why a pause before clicking is the best defence.

6. Prevention guidelines for employees

Check the sender, not just the name

Anyone can type “Visa” or “Customer Service” as a display name. Look at the actual address. In these samples, the “Visa” email came from an address with no real website name, and the “energy customer service” email came from a free Microsoft trial address.

Be suspicious of urgency and rewards

“Your account will be locked in 24 hours”, “LAST CHANCE” and “claim your €700” are written to make you act before you think. A real company does not threaten you by email, and a prize for a R$ 10 purchase is not real.

Look at where the button really goes

Hover over a link (do not click) and read the address at the bottom of the screen. In these samples, the buttons went to unrelated websites that were only weeks old, not to the company named in the email.

Notice generic greetings

“Dear User” and “Dear recipient” mean the sender does not know who you are. The genuine Google alert named the exact account.

A familiar website name is not proof

Scammers put pages on well-known services such as Google Cloud. A link on a trusted platform does not mean the page belongs to the company you think it does.

Passing a technical check does not mean safe

One sample, the roof advert, passed every technical check and was still misleading. If an email feels wrong, treat it as wrong and ask.

7. Do's and Don'ts

Do	Don't
Check the full sender address before trusting an email	Trust the display name alone
Type the company's website address yourself	Click "Verify now" or "Claim" buttons in an unexpected email
Hover over links to see the real destination	Open attachments you did not expect
Report suspicious emails to IT	Reply to the sender or forward the email to colleagues
Use a different strong password for every account	Share passwords, OTPs or bank PINs with anyone, ever
Turn on two-step verification	Rush because a message says "urgent"
Slow down and ask a colleague if unsure	Assume an email is safe because it looks professional

8. If you clicked or entered details

1. **Stop.** Do not enter anything else. Close the page.
2. **Tell IT straight away.** Reporting quickly is never punished, and speed limits the damage.
3. **Change your password.** Do it from a different device, or by typing the real website address yourself. Change it on any other account that used the same password.
4. **Turn on two-step verification** on the affected account.
5. **Check recent activity** on the account for anything you did not do.
6. **If money or banking details were involved,** call your bank at once.

9. Where to report

- **Inside the company:** your IT or security team.
- **In India:** the National Cyber Crime Reporting Portal at cybercrime.gov.in, or the helpline 1930 for financial fraud.
- **To the impersonated company:** most firms have a "report phishing" address on their official website.

10. Limitations and conclusion

- Six emails is a small sample. Four more reward and casino emails from the same collection were reviewed and left out because they repeat the pattern of Emails 03 and 04.
- Authentication results can differ between tools and over time. Email 05 passed at delivery but fails when its sender's records are re-checked now (see Email 05).

- Domain reputation and age were checked on 8 to 9 October 2026. VirusTotal results change over time, and a zero score would not prove a link is safe.
- I searched the front page of each link domain, not the exact tracking links in the emails, so the findings describe the domains.
- Email 01 is a template with no headers, so its classification rests on content alone.
- None of the samples carried an attachment, so attachment checks were not needed.

The clearest lesson is that the signs were visible before any tool was used: a famous name on a strange address, a deadline, and a button to somewhere unexpected. The tools confirmed what a careful reader could already suspect. If employees learn to pause on those three signs, most of these emails fail.

Appendix: evidence index

Everything referred to in this report is in the project repository.

File	Contents
samples/01-account-lock-template.txt	Template email from the task brief, link defanged
samples/02-fake-visa-prize.txt	Sanitised headers, text and links for Email 02
samples/03-fake-energy-tariff.txt	Sanitised headers, text and links for Email 03
samples/04-fake-reward.txt	Sanitised headers, text and links for Email 04
samples/05-roof-ad-suspicious.txt	Sanitised headers, text and links for Email 05
samples/06-legitimate-google-alert.txt	Genuine Google alert, headers only, personal data removed
screenshots/	Analyser, WHOIS and VirusTotal screenshots, named by email number and tool

Study references (used to understand structure, not copied): phishing_pot (rf-peixoto), phishing-mail-examples (autinerd).